Governance and IT Governance

Coporate Governance of IT, Compliance and Law is that part of *Information Technology* that deals with *people*, *practices, privacy and security*. It is a best practice and a legal obligation in the world. We will explore concepts in IT Governance like **laws, rules, security frameworks, service management frameworks and standards, and basic**

requirements for establishing IT contracts.

Unit 1: Motivation and Challenges of IT Governance

The section is explained based on a case study related to the breach suffered by UBER around November 14th 2016. The leakage came as a result of using Amazon Web Service resources with a program storec on GitHub that used hard coded *secrete key* to retrieve information. Code wrote and stored on Github is generally accessible so hackers used these secrete keys to compromise UBER's Systems and threatened to publish this data in the public if a ransom was not paid. According to the hackers, by the time they contacted the chief security officer at UBER, they had released part of the data in the **dark web** already. The *Dark Web* is the part of the internet that is not accessible via traditional search engines like *google, duck-duck-go* and thus requires more details before it can be accessed. Dark web consist of **legitimate and illegal buying and selling activities**. An example of an illegal activity on the dark web is the *sell of stolen personal data*. The hackers claimed that they had access to classical UBER Data including: Workers names, date of births, addresses, customer credit card details,drivers license information of UBER workers etc. Using the above description the chief executive officer had to take action to resolve this issue before UBER would be released to the entire public. There are a few questions that the Chief Security Officer had to answer to resolve this issue and avoid similar scenarios to occure in the future. First of all we need to understand certain terminologies.

- **IT governance**:

```
IT governance is a component of a firm's overall corporate governance program and
is a requirement under many local and international laws. It is also comprised of
the processes that ensure effective and efficient use of IT in enabling an
organization to achieve its goals.
```

Governance and IT Governance

Unit 3: IT Compliance

When a data breach occurs and goes gets to the public, the organization suffers multiple set backs which may include:

- Reputation: Organization is negatively perceived
- Trust: Shareholders, Partners and customers become reserved towards the company
- Contracts: Organization may experience a drop in service usage or transaction generation

In this chapter, it will be discussed how data breaches affects company's reputation and how the reputational loss can be measured.

Introduction to IT Compliance

In IT context, IT governance seeks to minimize or eliminate risk whereever it is possible. This is strongly supported by IT Frameworks and local/international laws. The most sensible risks to IT are:

- Unauthorised access to IT Systems
- Unauthorised access to Data
- Data breaches.

All thes can make cause much lost to the company ranging from denial of service, data deletion, loss in reputation as well as finance.

IT Compliance and IT Governance

The central point of IT Governance is *Risks and Control*. Risk and Control is generally handled in six steps. These include:

1. Determining the risk level the organization is willing to take.
2. Perform *risk assessment* to identify threats or weaknesses that can harm the organization. Risk assessment is an activity undertaken to systematically examine and test an organization's risk and vulnerability level.
3. Rank identified threats according to the level of damage it can cause to the organization. This could be via quantitative(score ranging from 1 to 10) or qualitative(low, medium, high) measures.
4. Design risk mitigation, avoidance, acceptance or transfer solution 5 Implement designed solution while taking cost into consideration. This is where threats are being handled.
5. Document mitigation, avoidance, acceptance or transfer approach for future use in similar situations.

In IT Governance, Risk is defined as the *effect of uncertainty on objectives*. But according to **NIST**, risk is a *measure of the extent to which an entity is threatened by a potential circumstance or event, and typically a function of:*

- The adverse impacts that would arise if the circumstance of event occurs
- Likelihood of occurrence

Risk = Threat * Vulnerability * AsseValue

Controls

Risk assessment is an examination of control while controls are used to mitigate risks. A control is a tool which measures how an activity or transaction is performed and carried out in compliance with *laws, regulations, internal policies, and best practices*. According to NIST and ISO, a control is a measure that changes or affecs risk in a way that risk could be decreased, have no effect or in the worst case, may increase risk. There are three control categories:

1. Admistrative
2. Physical
3. Technical/logical

There are six control types:

1. Preventative: Controls designed to stop or prevent circumstances or events from occuring. Updating/Patching systems is an example of a preventive control action.
2. Deterrent: Controls that aim to dissuade or discourage unintented actions which threaten an organization.
3. Detective: Controls designed to identify and reveal circumstances or events that have occured or are yet to occure. Logs and monitoring tools are examples of detective controls.
4. Compensatory: Substitutes for controls that are implemented because of the challenge in implementing the ideal controls for the situation. E.g Using one license by several person because of lack of funds.
5. Directive: These controls attempt to force an outcome through mandatory or required actions. Examplae: COSO's "tone at the top" control environment for senior executives.
6. Corrective: Restore a process, repair a damange or stop damage from further escalating. They work together with detective controls.

Control Shortcomings

Controls do not inherently eliminate risk, actions or events. This is because they are subject to factors that make them vulnurable. The drawbacks of controls include:

- Human erros which arise from unintentional mistakes.
- Fraudulent activities which are made to to fulfil personal or joint endeavors or as a result of opportunities derived from shared password, unguarded valuables or unlocked cash drawers.
- collusion, which is an agreement among two or more individuals to commit fraud. Also called conspiracy.
- Management may use their position to override or cancel effective control systems. This may be for persoanl or legitimate reasons. For instance, a manager may bypass rules to create transactions.
- Access creed, which is a situation where an employee can still actively use their credentials from a previous role at the same or different company to access systems are possible perform fraudulent activities. This can lead to undesired *segregation of duties*, as the right of legitimate person for the role may be compromised. Segregation of duties is a procedure that seeks reduce collusion by spliting responsibilities between two or more employees.

Inherent Risk and Residual Risk

- Residual Risk: These are risk that remain after risks assessment and the implementation of risks controls.
- Inherent Risk: Risk that exist in the absence of controls or when controls have been designed and implemented.

There are several approaches used by organizations to deal with risks. In general, it is done via one or more of the following actions:

1. Risk transfer: It doesn't mean that an organization becomes nonchalant, however, an organization transfers their risks to another entity. For instance, via insurance. In the case of data breaches or leakages, the insurance covers the cost entirely or partly.
2. Risk acceptance: Identified residual risk may be accepted by managers to avoid further expenses to handle this risk. In the event of damage as the result of accepted risk, the manager(s) who accepted the risk may be fired or reprimanded.
3. Risk avoidance: An organization may avoid purchasing or upgrading tools/services and continue running operations with existing tools that may no longer be actively maintained.

Examples of National and International Guidelines: Risk Management Standards and Frameworks

The COSO is a risk control framework that requires "tone at the top" directed at the executive of an organization. This framework has be absorbed by the U.S IT security framework called *System and Organization Control (SOC)*. The SOC is owned and maintained by the *American Institute of Certified Public Accountants (AICPA)*. Three other major global risk management/ risk control standards are: *ISO/IEC 27002, ISO/IEC 27005:2018 and ISO 31000:2018*. These standards discussed as follows

ISO 31000:2018

This standard is made up of 3 main risk management sections which are, *principles, framework and process*. It provides a set of best practices and guideliness, instead of mandatory requirements. First created in 2009 and last released was in 2018. This standard provides 8 principles which revolve around *value creation and protection*.

ISO 31000:2018 Risk Principles

- Integrated: Risk management should be embeded at all levels of the organization from code reviews in software development to background check & credential/education verification in human resource.
- Structured and comprehensive: A formalized risk management structure is recommended for consistent outcomes.
- Customized: The risk management system must be customized to fit the input and outcomes of the organization.
- Inclusive: All stakeholders must be involved in the formalized risk managment process. This is supported by the IT service management standards/frameworks like ITILV4 or ISO-1:20000.
- Dynamic: Risk management program must adapt to new risks as they are evolving. E.g handling deep fakes.
- Best available information: Quality(current and comprehensive) of information relating to risk is importanct.
- Human and cultural factors: Human factors include management override, mistakes and other weaknesses and strengths. Culturally generally refers to the organization culture(siloed, flat, open command hierarchy, etc).
- Continual improvement: Continuous improvement over time is a specific goal. This principle is common to other frameworks likt *ITIL and Six Sigma*.

Source: International Organization for Standardization (2018c). Used with permission.

ISO 31000:2018 Risk management Framework

Source: International Organization for Standardization (2018c). Used with permission.

The management framework of the ISO 31000:2018 is made up of six components as seen on the image above. These six components are described as follows:

1. **5.2 Leadership and Commitment**: The organization's top leadership(executives, board of directors) should allocated a formal budget and dedicated resources for the risk management program. They should also be commited to its risk management program to endorse it.
2. **5.3 Integration**: The organization's risk management program should be part of the its overall governance program. It should equally be embedded into every level of the organization.
3. **5.4 Design**: The risk management program should be designed to align with both internal and external context goals and outcomes.
    - **5.4.1**: External context here include relations with vendors, clients, government, regulatory bodies,and local, national & global economy. Internal context here include data flows, goals, desired outcomes, and the internal corporate culture and structure.
    - **5.4.2**: Risk management commitments provided by the executive management, the board and the top-level committees to the organization and stakeholders.
    - **5.4.3**: Assign roles, responsibilities and accountabilites to make individuals owners of risk management functions, and everyone in the organization know this.
    - **5.4.4**: Allocate adequate resources(qualified workers, budget) for the implementation of the risk management program. Additionally, top level management should be involved with the risk management progrom.
    - **5.4.5**: The risk management function implemented to possibly protect the organization unexpected expenses, regulatory penalties, reputational damage, or even cyber-related damages is adequately spread throughout the organization.

4. **5.5 Implementation**: The customized formal risk management program should be taken to production so that it is incorporated into the organization's decision-making process.
5. **5.6 Evaluation**: The risk management program should be assessed to measure its effectiveness overtime, and perform analysis to potentially reduce its budget. Evaluation is also required for improvement.
6. **5.7 Improvement**: Measures should be taken to improve the risk management program by increasing resources and budget.
    - **5.7.1 Adapting**: The risk management program should evolve and adapt to changing conditions internally and externally. It should equally create value to the organization. Example, advance in technology is an external factor that requires that the risk management program should adapt to it.
    - **7.7.2 Continually improving**: The risk management program should continuously be improved to fit to the organization's needs and be integrated in the organization's operations. If any finding or shortcomings are discovered during continuous monitoring, adequate action is taken for remediation.

ISO 31000:2018 Risk Management Process

This standard provides six activities that should be incorporated into an organization's policies, procedures, and practices. These activities are contained in section six of the standard and described below:

6.2 communication and Consultation: The organization's risk should be communicated to stakeholders especially if it concerns management's decision process. Consulation on the other hand is the involvement and participation of stakeholders and other experts parties in risk-related decision-making, with the aim to include all experts, and assign roles and responsibilities. **6.3 Scope, context, and criteria**: Risk management is tailored to the unique goals, desired outcomes and relevant risk areas of the organization. This process is further broken into small subprocess described as follows: - **6.3.1 Defining Scope**: Questions should be asked to define the scope of operation. E.g Are ther laws and regulations that require certain elements within our risk management program? - *6.3.2 External and Internal context**: The risk management program should align with the internal and external operational environment of the organization. - **6.3.3 Defining risk criteria**: The risk criteria are fairly unique to each organization as it takes into account the industry type, competitors, regulators/regulatory burden, threat surface, corporate culture, goals, outcomes, stakeholders, management style and geographic locations. The risk criteria should change as the organization changes. It should incorporate directions for how risk criteria is measured/scored and reviewed. **6.4 Risk assessment**: This is composed of risk identification, risk analysis and risk evaluation. - **6.4.1 Risk identification**: Ask questions that will simplify the identification of risk. E.g what is the organization doing to capture risk, and how are they identified?. What controls are in place to minimize the event of not capturing risk?. Where is risk coming from?. Where in the organization do threats and vulnerabilities lurk? - **6.4.2 Risk analysis**: What is the level of risk? Consider the likelihood and impact of negative outcomes and how effective the current inventory of controls is. - **6.4.3 Risk evaluation**: This is the result made after obtaining information from risk identification and risk analysis. Potential decision could be: do nothing or conduct further test to obtain more information about risk. **6.5 Risk treatment**: Steps taken to address risk. This involves the following: - **6.5.1 Selection of risk treatment options**: Perform a cost benefit analysis on treatment options. Potential treatment could be: risk acceptance, risk transfer, risk avoidance and risk sharing. - **6.5.2 Preparing and implementing risk treatment plans**: The details for the selection of a treatment plan are documented formally including information regarding the selection that was made, who made the selection, were there alternatives, and when the treatment will take place and its costs. **6.6 Monitoring and review**: The performance of the risk

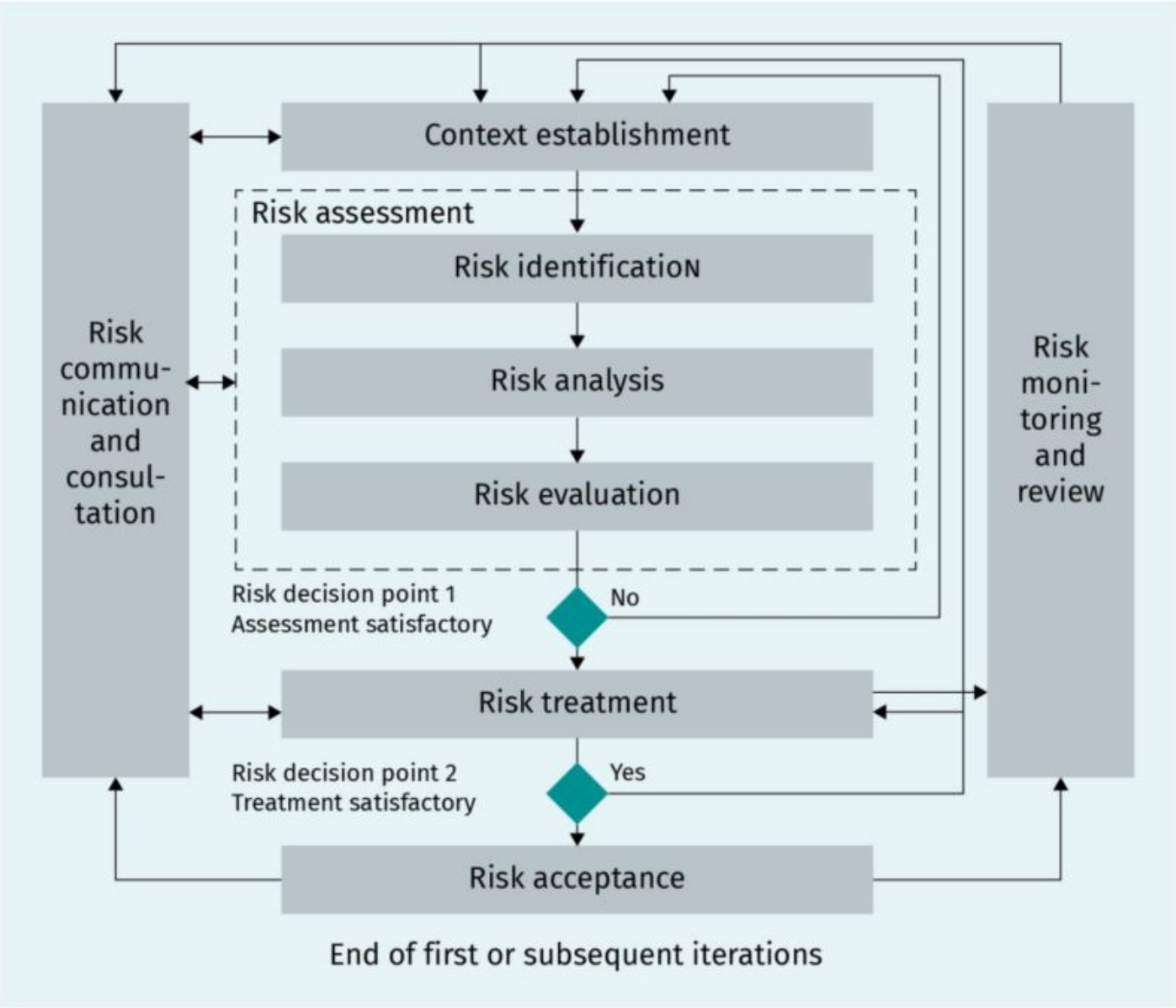
management program as well as its results are evaluated. Formal reviews and remidiation of shortcomings are documented and communicated to all relevant stakeholders. **6.7 Recording and reporting**: This activity involves the communication of risk events, when a set threshhold is reached or exceeded, to internal and external stakeholders. This can be done at regular time intervals.

ISO/IEC 27005:2018

This standard also suggest best practices, which are not mandatory, for *Information Security Risk Management*. The latest version of this standard was released in 2018. The ISO 27005:2018 is composed of seven clauses ranging from section seven to twelve. These clauses are listed below:

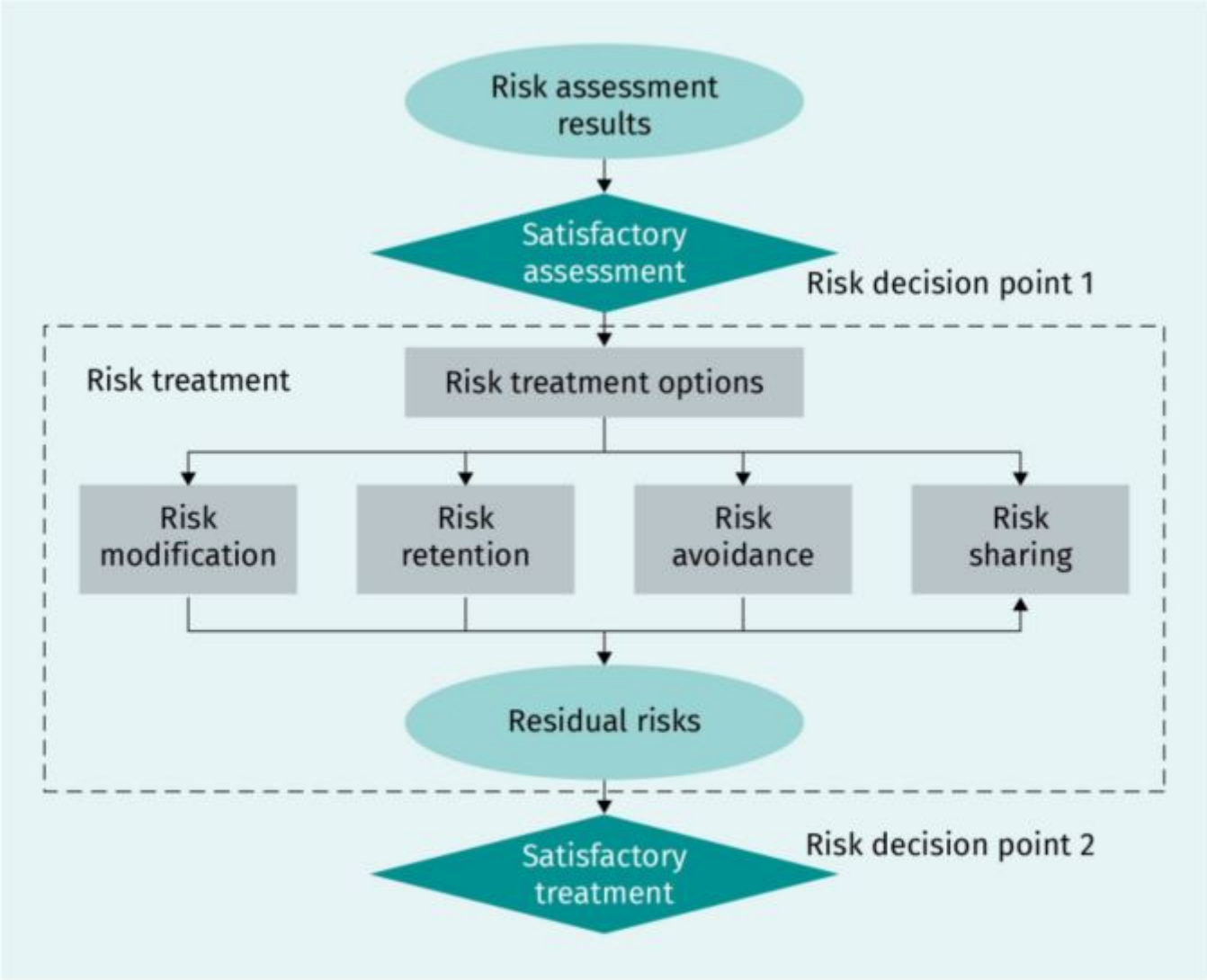
- 7. Context Establishment
- 8. Information Security Risk Assessment(which includes Risk Identification/Risk Analysis/ Risk Evaluation).
- 9. Risk Treatment
- 10. Information Security Risk Acceptance
- 11. Information Security Risk Communication and Consultation
- 12. Information Security Risk Monitoring, Review, and Improvements.

There are also six annexes (Annex A through Annex F). The annexes are detailed instructions on how to perform a risk assessment. The Risk Assessment process of this standard is made up of eight steps. These are presented in the following image.



Source: International Organization for Standardization (2018a). Used with permission.

The following image illustrates the Risk Treatment process suggested in ISO 27005:2018.



Source: International Organization for Standardization (2018a). Used with permission.

Elaboration of **Context Establishment**

- 7.1 General considerations: The bounderies for the organization's approach to risk management is set.
- 7.2 Basic Criteria
    - 7.2.1 Risk Management Approach: Select the approach for which resources are available for its implementation. One approach may be continuous monitoring via the installation of third party software.
    - 7.2.2 Rist Evaluation criteria: Assign risk values to assets in the organization based on their criticality with regards to the risk events.
    - 7.2.3 Impact criteria: How much damage will be caused if a risk events occurs.
    - 7.2.4 Risk acceptance: In the event of risk acceptance, ISO reommends following a formal approval process at every instance with defined criteria and limits.
- 7.3 Scope and boundaries: All assets must be included in the risk assessment phase. The current and complete assett list should be document in the organization's information securiy policy (WISP).
- 7.4 Organization for information securiy and risk management: This involves the creation of a formal information securiy risk management program. With regards to this, roles and responsibilities are assigned.
- 8 Information Security Risk Assessment

    - 8.1 General description of the purpose of risk assessment. For instance, how will risk assessment lead to the identification of risks and what is currently in place to treat or counter identified risks.
    - 8.2 Risk Identification
        - 8.2.1 Introducation to risk identification: Seeks to determine what that can happen, how they can happen and the damage they can cause to the organization.
        - 8.2.2 Identification of assets: Any item valuable to the organization. 8.2.3 Identification of threats: Identify and rank threats according to their level of sensitivity. 8.2.4 Identification of existing controls: what is in place? 8.2.5 Identification of vulnerabilities: Identify all weakness and rank them with the most vulnerable asset being rank highest. 8.2.6. Identification of consequences: Define the worst case scenario and the impact of this case if it occurs. Its impact can be expressed quantitatively or qualitatively.
    - 8.3 Risk analysis: This aims at estimating the likelihood of a risk event to occur and to measure its impact. The risk events are rated quantitatively or qualitatively alongside the level of damage it can cause if it occurs.
        - 8.3.1 Risk analysis methodologies: Use quantitative and qualitative methods to measure the impact of risk events.
        - 8.3.2 Assessment of consequences: Express the impact or level of damage of a risk event in monetary and non-monetary(e.g reputational damage) terms.
        - 8.3.3 Assessment of incident incident likelihood: Based on a formal assessment procedure, the likelihood of a risk event should be monitored, and resources added/reduced if necessary.
        - 8.3.4 Level of risk determination:
- 9: Information Security Risk Treatment
    - 9.1 General description of risk treatment: For every risk event, it must be decided whether it will be accepted, avoided or transfered etc.
    - 9.2 Risk modification: The organization needs to take measures to to reduce risk. Some measures include: creating new controls, deleting existing ones, or changing existing controls. Through this risk residual can be reduced to accepted levels. Additionally, it is recommended to perform a cost-benefit assessment before implementing a solution.
    - 9.3 Risk retention: How much risk does the company want to accept?. This question must be answered.
    - 9.4 Risk Avoidance: These are the activities that an organization will start or stop doing because of risk events they can't avoid. -9.5 Risk sharing: This is also known as risk transfer. E.g Getting an insurance subscription.
- 10: Information Security Risk Acceptance: In a cost-benefit analysis, if the cost of a control is higher than the damage the risk can cause, then the risk is in most cases accepted.
- 11. Information Security Risk Communication and Consultation: This encourages the spread of risk information in the organization and ensuring that experts in risk areas are involved in the risk-based decision-making.
- 12. Information Security Risk Monitoring, Review, and Improvement:
    - 12.1 Monitoring and review of risk factors: In the best case, the company should implemen continous monitoring to follow-up the evolution of risk factors. Additionally, a risk management program is also implemented which equally evolves with technological changes.
    - 12.2 Risk Management monitoring, review, and improvement: Continuous monitoring with real-time alerts are highly recommended. The monitoring documentation should be constantly

maintained by the individual incharged. Finding made during the monitoring process should be used for improvement.

Details describing how a Risk Assessment should be performed are discussed in the following points. These details are contained in six Annexes and should be part of any discussion relating to ISO/IEC 27005:2018.

1. Annex A: This annex focuses on defining the scope and boundaries of the information security risk management process. It does this in 3 parts which (1) relate to the study of the makeup or composition of the organization, (2) the constraints or limitations affecting the organization the (3) constraints on the scope of the risk program such as industry-specific regulations, laws, or inherent risks which can never be completely eliminated, such as risks involved with nuclear activities or mining.
2. Annnex B: This focuses on identifying and valuing assets and conducting an impact statement. This annex is madeup of three sections: (1) asset identification, (2) asset valuation, and (3) impact assessment.
3. Annex C: Focuses on illustratin threats examples. Threats include: Denial of Service(DOS), advanced persistent threats(usually carried out by government agencies), ransomware, and phishing.
4. Annex D: Focuses on the provision of vulnerabilities and methods for assessing vulnerabilities. Examples of vulnerabilities are: Cybersecurity of sensitive data exposure and inadequate logging and monitoring(for instance, turning off alerts or systems are not routinely monitored).
5. Annex E: Provides a template for a detailed information security risk assessment. This template contains quantitative scoring methods for rating threats and materials for assessing values for the likelihood and possible consequences of risks.
6. Annex F: Focuses on the contraints and limitations used in risk modification. These contraints are centered around adding, removing, or modifying controls to decrease residual risk to a level that is acceptable to the organization and its risk appetite.

ISO/IEC 27002:2013

This standard provides best practices for implementing an *information security risk system or program*. Just like the **ISO 31000:2018 and ISO/IEC 27005:2018**, it acts as a guideline with suggested best practices withou any mandatory requirments. The most recent version was released in 2013 and is made up of the security control clauses. The clauses range from section 5 to 19, with 35 total control objectives.

Clauses	**Controls**
5. Security Policy Management	5.1 Provide management direction and support
6. Corporate Security Management	6.1 Establish an internal information security organization
7. Personnel Security Management	7.1 Emphasize security prior to employment
	7.2 Emphasize security during employment
	7.3 Emphasize security at termination
8. Organizational Asset Management	8.1 Establish responsibility for corporate assets
	8.2 Develop an information classification scheme
	8.3 Control how physical are handled
9. Information Access Management	9.1 Respect business requirements

Clauses	Controls
	9.2 Manage all user access rights
	9.3 Protect user authentication
	9.4 Control access to systems
10. Cryptography Policy Management	10.1 Control the use of cryptographic controls and keys
11. Physical Security Management	11.1 Establish secure areas to protect assets
12. Operational Security Management	12.1 Establish procedures and responsibilities
	12.2 Protect your organization from malware
	12.3 Make backup copies on a regular basis
	12.4 Use logs to record security events
	12.5 Control your operational software
	12.6 Address your technical vulnerabilities
	12.7 Minimize the impact of audit activities
13. Network Security Management	13.1 Protect networks and facilities
	13.2 Protect information transfers
14. System Security Management	14.1 Make security an inherent part of information systems
	14.2 Protect and control system development activities
	14.3 Safeguard data used for system testing purposes
15. Supplier Relationship Management	15.1 Establish security agreements with suppliers
	15.2 Manage supplier security and service delivery
16. Security Incident Management	16.1 Identify and respond to information security incidents
17. Security Continuity Management	17.1 Establish information security continuity controls
	17.2 Build redandancies into information processing facilities
18. Security Compliance Management	18.1 Comply with legal security requirements
	18.2 Carry out security compliance reviews

The following are detail explanations of the controls listed above.

- 5. Information Security Policies
  - 5.1 Management direction for information security: Like seen in previously discussed standards, this policy also emphasis the need of *executives/board/committees* in engaging to a formal IT security policy and program.
- 6. Organization of Information Security
  - 6.1 Internal organization: This best practice emphasis on the need of roles and responsibilities in the IT security segment of the organization. IT security professionals should be up to data and

follow defined ethical guidelines in their duties.
    - 6.2 Mobile devices and teleworking: This is purposely meant for remote work. Remote workers should take measures to avoid being compromised by external parties to who seek to have unauthorised access to the organization's systems or data. Examples are physhing emails. Companies should provide training and test employees on their aptitute to identify threats.
- 7. Human Resource Security
    - 7.1 Prior to employment: In some countries background checks of the employee is performed to detect possible criminal activities.
    - 7.2 During employment: Once every year, it is recommended to perform background checks of the employee to stay up to this. Usually, advise should be seeked from a lawyer before performing this.
    - 7.4 Terminiation and change of employment: Employee user account should be deleted or deactivated from the company's system at the end of their contract.
- 8. Asset Management
    - 8.1 Responsibility for assets (who has what): Implement policies and procedures on the use of company and personal devices, software, application and communication tools. Also perform inventory and track all company devices, and ensure that employees consent to usage policy.
    - 8.2 Information Classification: Classify data based on their level of criticality and implement access controls to the various defined classes. For instance, data in archives should be encrypted at rest.
    - 8.3 Media handling: Corporate devices holding company data/information should be handled according to corporate policies. In the case where a device needs to be disposed or is lost, then there must be a possibility to erase all the information on this device.
- 9. Access Control
    - 9.1 Business requirements of access control: Give employees the priveledges they need to perform their tasks and not more than that.
    - 9.2 User access management: Ensure that employees get access rights and previleges tied to their roles or role category, and their responsibility levels.
    - 9.3 User responsibility: Train employees on IT security topics. Security aspects like creating strong passwords, recognizing phishing mails and processing personal identifiable information should be components of the training.
    - 9.4 System and application access control: Similar to the 9.1 to 9.3 but restricted to individual systems. Not every employee should have the need to access every system in the organization.
- 10. Cryptography
    - 10.1 Cryptographic controls: This control emphasises on the need of access key management to control access to data. Additionally, encryption is a data security principle defined in GDPR.
- 11. Physical and Environmental Security:
    - 11.1 Secure areas: Secure areas should be highly restricted and only accissible by following strick and mandatory processes. For instance, server room of a company should not be accessed carelessly by anyone.
    - 11.2 Equipment: Inventory must be conducted periodically to ascertain the state of all equipment belonging to the organization. This ranges from mobile phone to laptops upto and including air conditioning equipment.

12. Operations Security: 12.1 Operational procedures and responsibilities: change management program related to change request(e.g change in tool) and approval/authorization must be in place. 12.2 Protection from malware: Updating software and employee training are emphasised by this control.

12.3 Backup: Necessary for recovering lost information in cases of unforeseen or unexpected events like floods, earth quake, wars etc. 12.4 Logging and monitoring: For tracing access activities and for fraud detection. 12.5 Control or operational software: Ensures that licenses are well managed. Only required licenses should be maintained. Licenses of employees who have left the company should be terminated. 12.6 Technical vulnerability management: Watch out on systems requiring regular updates and patching. Eg Windows server 2019. 12.7 Information systems audit considerations: IT audits should be performed in periods of low business activities. This could be at night or during peak holiday season when most employees are on holiday and when the system is not highly be used by customers.

13. Communications Security: 13.1 Network security management: Employees and guests should not be active on the same network. 13.2 Information transfer: Personal transfer of sensible data e.g PII or company's intellectual data, a non-disclosure agreement policy should be followed.
14. System acquisition, development and maintenance: 14.1 Security requirements of information systems: Understanding GDPR and how it is applicable in the company is very relevant. For instance, encryption. 14.2 Security in development and support processes: DevOps should have a formal security program with policies and procedures. 14.3 Test data:
15. Supplier Relationships: 15.1 Information security n supplier relationships: Service level agreements must be set to ensure standards are respected when dealing with vendors, suppliers and contractors. 15.2 Supplier service delivery management: A suppliers service delivery should be review and this should be made as part of the contract. Downtimes should be clearly justified and level of penalty for incomplete services should be defined.
16. Information Security Incident Management 16.1 Management of information security incidents and improvements
17. Information Security Aspectss of Business Continuity Management 17.1 Information security continuity: This controls focuses on the Business Continuity Program (BCP) and its Disaster Recovery(DR) program. In the event of unexpected scenarios like wars, natural disasters or data breaches, these systems should go live to keep the business running until normalcy returns. 17.2 Redundancies: For the sake of business continuity, an organization should have back security, data centers, internet provider etc.
18. Compliance: 18.1 Compliance with legal and contractual requirements: Mandatory requiremens like following regulatory measures, applying laws and respecting privacy should be part of the contracts when dealing with vendors, contractors and suppliers. This requirements include: data encryption, data breach/incident notifications, and non-disclosure agreements. 18.2 Information security reviews: On an annual basis, IT audits should be performed by third parties. In some cases, laws may require vulnurability checks to be done frequently. At the end of the audit, a report must be shared with the executive. This should include weaknesses or any findings that require attention from the management. The management is expected to respond with an action plan and an estimated date of completion for the implementation of the action plan.

We've discussed three standards that suggest good practicesses for the implementation of an **Information Security Risk System or Program**. Now we'll discuss IT Security Frameworks.

IT Security Frameworks: SOC 2, NIST 800 Series, ISO 27001:2013

What is SOC 2?

This is part of the American Institute of Certified Public Accountant's (AICPA) SSAE 18 Attestation standard. It is maintained and updated by AICPA. The COSO component of *risk managament and anti-fraud measures* have been incorporated into the latest release of the SOC 2. In five criteria, SOC 2 leverages a framework of

controls used to tests the design and effectiveness of implemented controls responsible for ensuring security in IT systems and controling the processing of client/customer data. These criteria are: **Security, Privacy, Processing integrity, availability, annd confidentiality**. SOC 2 reports are being sold as the tools of choice for vendors. This is with the aim to show case the commitment of SOC 2 to *risk management and system security*. SOC 2 reports are only signed or attested by U.S Certified Public Accountants (CPA) and have a validity period of one year.

What is NIST 800-30, 800-53?

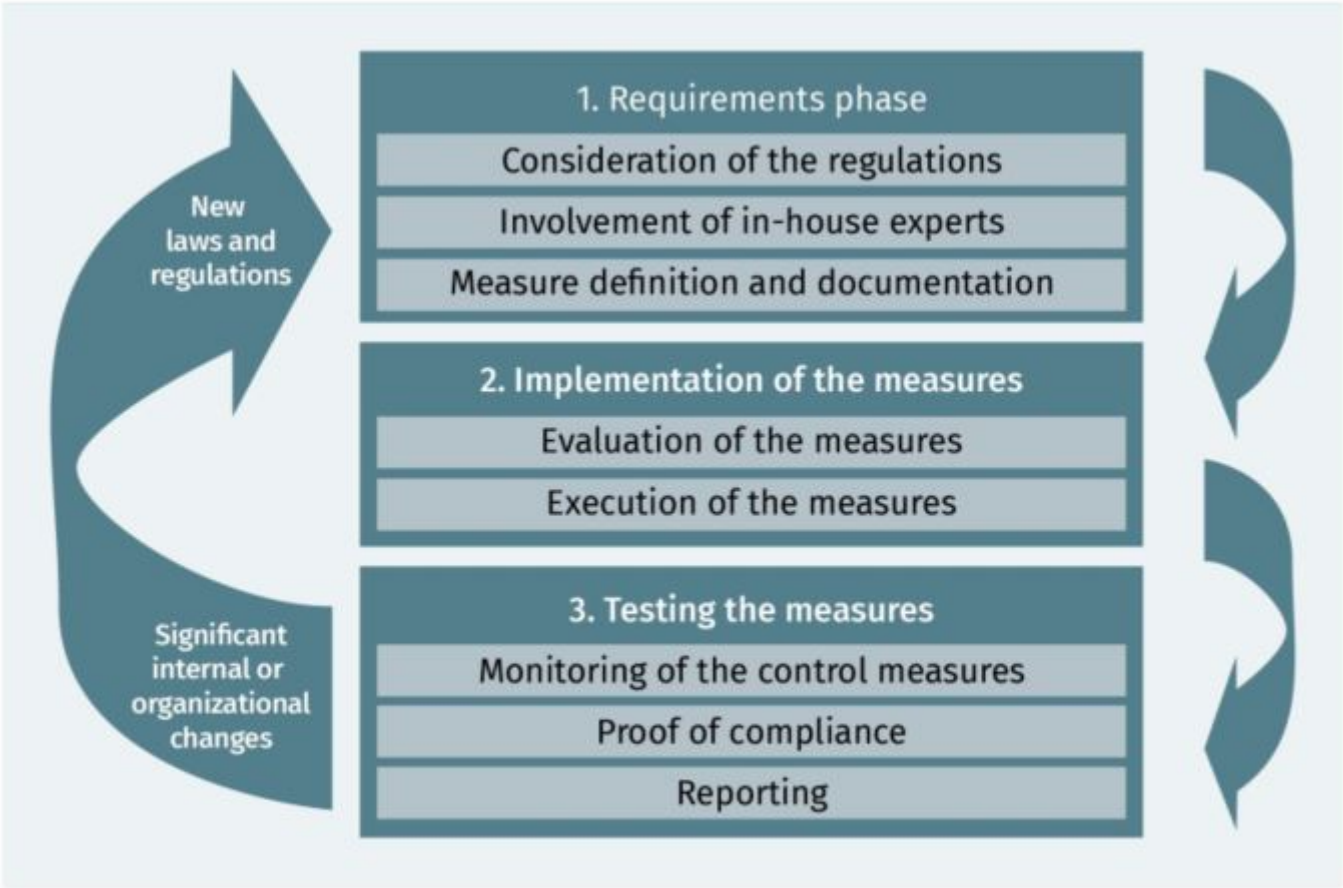
NIST 800-53 is an *IT security framework* developed by the U.S National Institute for Standard and Technology(U.S NIST). Initially, it was used to test IT Security Controls for US government entities and their vendors or contractors. Today, it has been widely adopted by several other companies. On the other hand, NIST 800-30 is a *Risk Management framework*. In general the National Institute for Standard and Technology (NIST) has created several frameworks, including 800-53 and 800-30 in its 800 series of IT frameworks.

What is ISO/IEC 2 27001:2013?

ISO/IEC 27001:2018 in other words ISO 27001 is the ISO/IEC Information Security Management System(ISMS) Standard. This framework contains 14 groups with 35 control categories, along with 114 individual controls and a *minimum of 15 mandatory written documents* which need to exist and be *fit for purpose*. An ISO 27000 Information Security Assessment Report can *only* be signed by an ISO-27000 certified individual(ISO Lead Auditor) working at a certified body(ISO certified audit firm). When an ISO 27001 Lead Auditor successfully tests, reviews and documents the state of the IT Management System, following the ISO 27001 requirements, the organization becomes ISO 27001 certified for a period of three years. During this period, the Lead Auditor will visit the firm to confirm that the organisation is using the ITMS program.

IT Compliance: Typical Measures

Laws and Regulatory bodies mandate companies to be IT Compliant among others. The following figure shows a three phase(Requirement, Implementation and Test) action-oriented plan that companies can adopt in the implementation of rules to be IT compliant.



Source: Derlam (2017), based on Disterer & Wittek (2012).

The phases of the action-oriented IT compliance process are discussed below:

1. Requirement Analysis Phase

The key points here are:

- Consideration of the regulation
- Involvement of in-house experts
- Measure definition and documentation

Because of the ambiguity or overlappings that exists in regulations stated by law or regulatory bodies, companies need an in-house expert in IT compliance topics. This expert is responsible for interpreting regulations and guiding the implementation of those required by the company. Before implement IT compliance regulation, the company must conduct an IT compliance requirement analysis. This can be done in of two approaches, namely:

- Regulatory and legal perspective
- Requirements of the company's various stakeholder groups.

It is recommended to follow the stakeholder groups approach. This is because different stakeholders understand the various needs of an organisation. As such they will precisely define the requirements of an organisation that need to be IT compliant. Additionally, it is also recommended to include stakeholder when defining a formal IT governance program for an organisation. By adopting this approach, an organisation will avoid fines, regulatory penalties and reputational damage. We saw that there exist frameworks(e.g COBIT)

used in the implementation of IT governance programs. This also applias to IT compliance. The advantage of adopting IT compliance frameworks is that:

- It reduces implementation effort
- It covers many legal requirements
- It includes trial-and-testing measures.

Example frameworks or reference models that can be used to facilitate IT-compliance include:

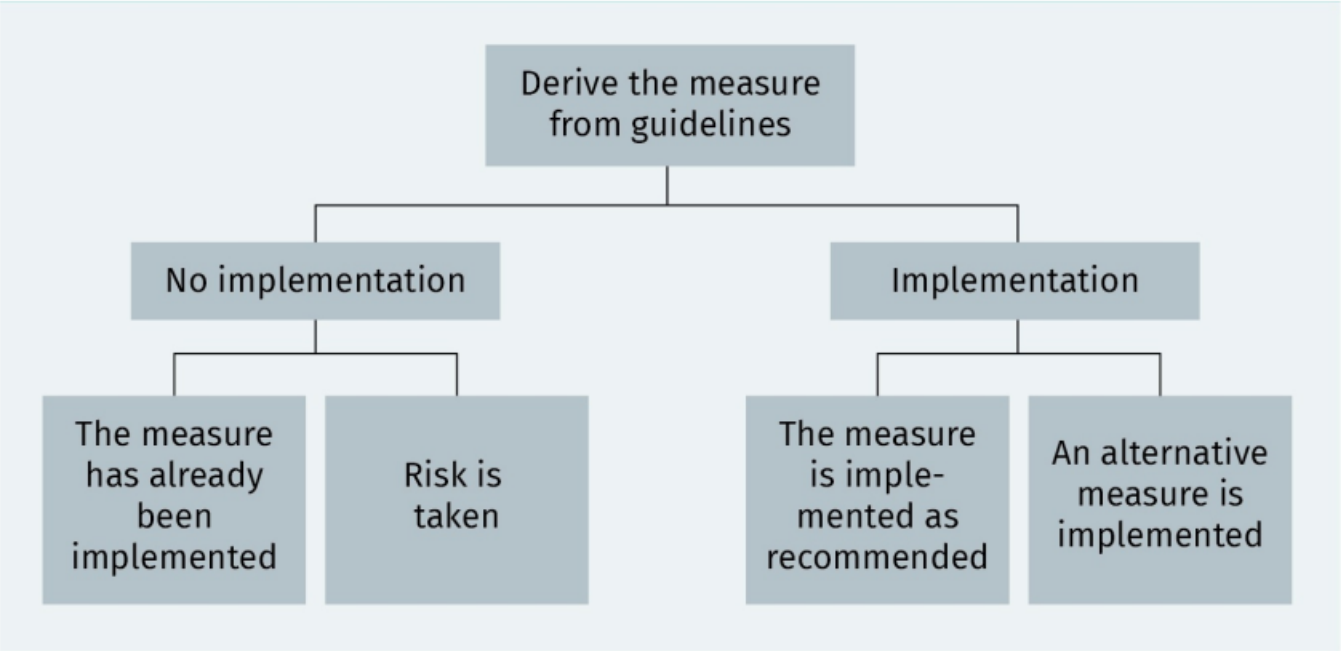
- COBIT Framework
- IT-Grundschutz Katalog published by Bundesamt für Sicherheit in der Informationtechnik(BSI) or German Federal Office for Information Security.

The different groups of stakeholders and their requirements are listed below:

Stakeholder group	**Requirements**
Equity investor	Monitoring and Controlling IT risk, among others
Auditor	Alignmeent with risk management methods (COSO Enterprise Risk Management)
Corporate management	Coverage of the protection goal confidentiality, integrity, and availability
Corporate management (continued)	Controls of the accounting-relevant IT systems
IT management	The framework is based on the elements from established frameworks such as COBIT, etc
Etc,.	text
source	Derlam (2017), based on Falk (2012)

2. IT Compliance: Implementation of the Measures Stage

After the requirement analysis phase i.e the compilation of company specifications and definition of measures is done, the implementation of the defined measures are initiated in this phase.The first step in this phase is the selection of measures to implement bases on the expected risk. It is recommended to perform a cost-benefit analysis before selecting or disqualifying a measure. In the case a measure will not be implemented due to risk acceptance, the reasons for arriving at this decision should be documented. Control mechanisms like guidelines, procedures, organisational structures or instructions for action should be introduced to measure the efficiency and effective of the measures. The following shows a possible decision tree that can be used to evaluate measures.



Source: Derlam (2017), based on Disterer & Wittek (2012).

3. IT compliance: Examination of the Measure Stage

This phase is concerned with testing the measures, procedures and other control mechanisms to assess the level of efficiency and effectiveness of the implemented measures. This step is relevant for quality assurance. The following table presents activities that can be used during testing.

Monitoring of the control mechanisms	Deviation analysis and maturity determination of measures and processes, such as with the COBIT 5 process assessment model, with regard to deviations and gaps to achieve the defined target state
	Key figure monitoring: Defined key figures, which can be taken from a framework or formulated specifically for the company, to monitor the fulfillment of the purpose or the efficiency and effectiveness of the measures and processes
Proof of conformity with the rules	It must be possible to comprehensively demonstrate IT compliance to internal departments, such as management and internal auditing, and external auditors, such as auditors and regulatory authorities.
	In practice, it is advisable to set up a regulatory database in which the regulatory, legal, and internal requirements and the associated measures, processes and control mechanisms are stored in order to compose meaningful reports at any time.
Compliance reports	Various compliance reports can be generated from the regulatory database to publicize continuous monitoring and improvements within the company, thus creating transparency and engaging stakeholders.
	Annual Compliance Report Addressees: IT management, executive management, board of directors Content: • Assessment of compliance with all IT compliance requirements and measures, including risk assessment • Presentation and analysis of key figures and maturity models • Need for action and suggestions for improvement
	Quarterly Compliance Report Addressee: IT management Content: • Quarterly documentation and assessment of the compliance with all IT compliance requirements and measures, including risk assessment • Need for action and suggestions for improvement
	Ad Hoc Compliance Report Addressee: IT management Content: • Case-by-case description of the effects of individual events incl. the initiated measures and their effectiveness • Documents and describes (on a case-by-case basis) the impact of individual events

Source: Derlam (2017), based on Disterer & Wittek (2012).

Unit 4: Basic IT Protection According to BSI

In a technology driven world, companies of all sizes depend on IT Systems. In the event, that the IT system is compromised, e.g system failure, DDoS etc, several activities could go wrong in the company including the following:

- Loss of availability: System becomes inaccessible for all employees resulting in the inability to perform routine or strategic task.
- Loss of confidentiality: Personal Identifiable Information or coporate critical information may is breached, which can damage the reputation of an individual or company

- Loss of integrity: Individual's information may be altered or falsified thus making them incorrect. This may lead unexpected charges, false deliveries, wrong identity etc.

For these reasons, it is very relevant for companies to build secure IT systems. IT security is the protection of information stored digitally, on paper and in our heads. Information Security Management (ISM) is an approach that involves the planning and controling of tasks required to *information security*. ISM includes an emergency and crisis management system also called *Disaster Recovery (DR) or Business Continuity Plan (BCP)*. Such systems are set to go live to keep a business running in the case of emergencies or disaster, until the system is put under control by safe hands. The IT-Grundschutz of the German Federal Office of Information Security(BSI) provides support for the design of crisis or emergency management systems. IT-Grundschutz (Basic Protection) contains a contruction kit which helps in identifying and applying security measures based on the basic IT security requirements. This kit has a success rate of 80% and in cases where security needs to tightened, then the IT-Grundschutz can be fortified with extensive measures. This IT-Grundschutz is applicable for companies of all sizes as it can be adjusted to the company's requirements. Companies can be IT-Grundschutz compliant by being ISO-27001 as this proofs that the company has implemented sufficient IT-Security measures.

Overview and Structure of IT-Grundschutz

The IT-Grundschutz was created in the mid-1990s and in 2017 it was modernised by updating its Catalog. As a result the It-Grundschutz is replaced by the *IT-Grundschutz Compendium*. This acts as an encyclopedia for IT security best practices. In the meantime, companies are still allowed to operate on the IT-Grundschutz security guidelines. The BSI has published three documents on the IT-Grundschutz which are:

- BSI standard: Recommended methods, processes, procedures and approaches are described here.
- IT-Grundschutz compendium: Components and their hazards and security requirements are described here.
- Supplementary docs like guide to basic security. This is available free of charge on the BSI website.

1. **The BSI Standards**

In the modernisation process, BSI 100-x was replaced by BSI 200-x with the exception of 100-4.

- BSI Standard 200-1: This is the management system for information security.
    - This defines the general requirements of an ISMS for the IT-Grundschutz approach. These requirements are within the framework of ISO/IEC 27001 and takes into account several suggestions of the ISO/IEC 27002.
- BSI Standard 200-2: IT-Grundschutz methodology.
    - This standard contains tried-and-tested instructions for implementing an ISMS in practice and in accordance with BSI standard 200-1. It also provides the procedure for the development of a company's IT-Security infrastructure.
- BSI Standard 200-3: Risk analysis based on IT-Grundschutz
    - This standard an effective and efficient method for conducting a supplementary security analysis.
- BSI Standard 100-4: Emergency management
    - It describes a method for establishing an emergency management system. It is based on BSI standard 100-2 and supplements it where necessary.^

IT-Grundschutz Catalog and IT-Grundschutz Compendium

Basically, the IT-Grundschutz provides three types of catalogs which are: *Component catalog, threat catalog and measures catalogs*. Althaugh the IT-Grundschutz has be replaced by the IT-Grundschutz compendium, these catalogs have been modified and embedded into the It-Grundschutz catalog. These three components are described as follows:

1. **Component Catalog**

Components like IT, Network, Infratructure and security management are described in this catalog.

2. **Threat Catalog**

This catalog contain descriptions of threats that could arise from unexpected events(absence of staff) or intentional acts(destruction of equipment).

3. **Measures Catalog**

This catalog contains description of measures that are used to address threats. However, they were eliminated from the IT-Grundschutz during modernisation. As a result, the IT-Grundschutz compendium now allows specification of requirements to be met within the individual components of the total 80 components. These requirements are generic and abstract than measures, thus creating more freedom as to how components are protected. However, the IT-Grundschutz compendium provides less assistance in this task.

The compendium is divided into the follow parts:

- Role definition
- Glossary
- Elemental threats
- components
- Process components
- System components

The building blocks of the compendium are assigned to one of ten layers classified in process and system components.The process modul is implemented once for the entire organisation while the system modul is implemented once for each system. These layers are listed in the image below:

Process Components	System Components
ISMS (Security Management System)	INF (Infrastructure)
ORP (Organization and Personnel)	NET (Networks and Communication)
CON (Concepts and Procedures)	SYS (IT Systems)
OPS (Operation)	APP (Applications)
DER (Detection and Response)	IND (Industrial IT)

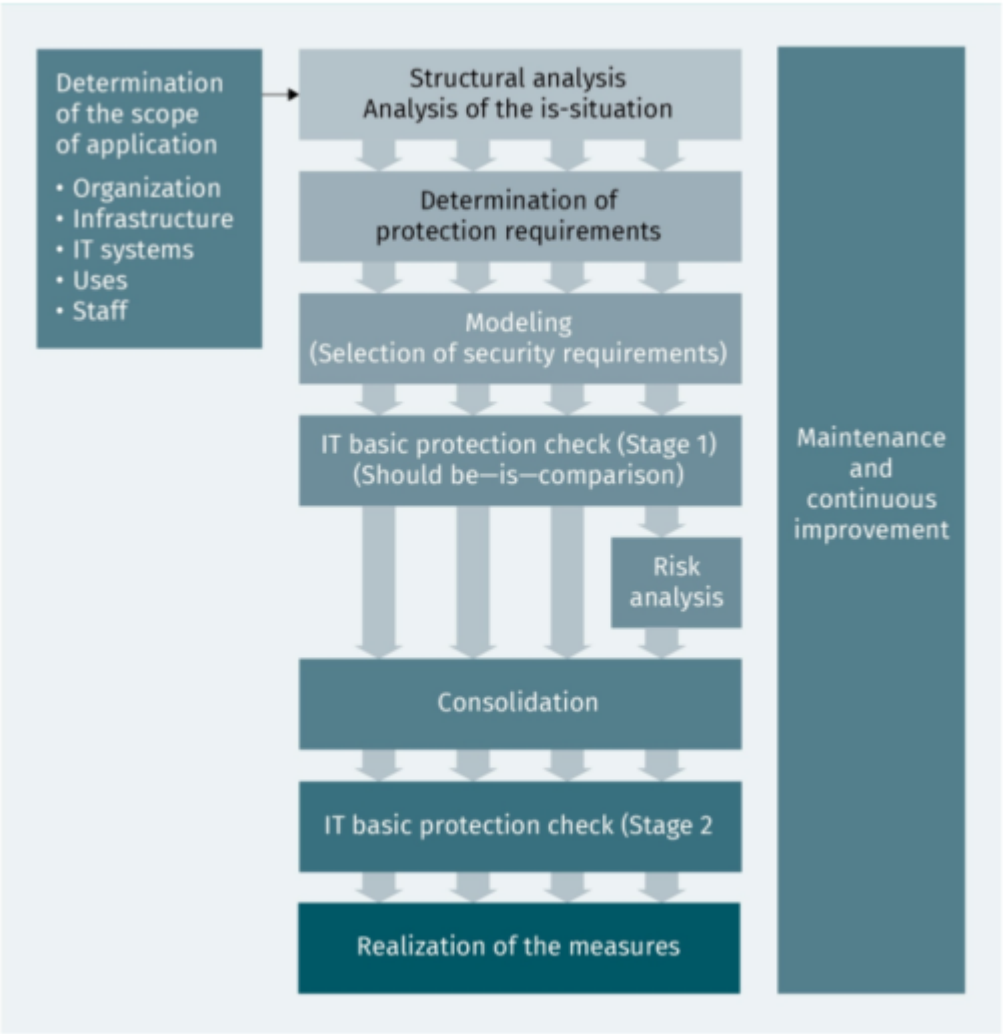
Source: Derlam (2017), based on Bundesamt für Sicherheit in der Informationstechnik (2017a).

Approach to IT Governance

Protective measures are formalised IT Security programs with approved policies and procedures put in place by organisations. This measures are should be reviewed annually. For the successful implementation of these protective measures, a well planned and control IT security process must be followed. This plan and control IT security process for implementing protective measures follow six steps which are:

1. Structural analysis: The main component (e.g IT systems) of the IT network are recorded and their relationships to one another are noted.
2. Determining the need for protection: The level of damage that could arise from loss of *availability, confidentiality and integrity* is ranked(normal, high, very high) to determine the need for protection. Qualitative measurements are used to be able to assess the level of damage an event can cause based on the capabilities of the company being assessed. These qualitative measures can be interpreted as follows:
    - normal: the level of damage is limited and manageable
    - high: the level of damage can be considerable
    - very high: the level of damage can reach existential or catastrophic levels.
3. Modeling (selection of security requirements): The relevant security requirements are selected based on the of the structural analysis.
4. IT-Grundschutz check: A review conducted to determine the requirements that have been met.
5. Risk analysis: A supplementary risk analysis is performed in the event of high risk. As a result, additional measures may be required.
6. Implementation: The selected measures are implemented to meet the requirements

The visual representation of these steps is shown on the following image



Source: Derlam (2017), based on Bundesamt für Sicherheit in der Informationstechnik (2017b).

Usage Example of IT Governance

Read example in course book!

Unit 5: Introduction To IT Service Management

Atlasian is the company that produces *Jira, Trello, Bitbucket and other project & service management solution*. They define **ITSM** as *the manner in which IT teams manage the end-to-end delivery of service to customers*. The end-to-end service delivery includes all the development stages along side the hardwares used for a software development project. Stages include: *initial planning, development/operations (DevOps), quality control, test, production/rollout and change management. Hardware include: drives, servers, mobile devices etc.

According to *ServiceNow**, a top ITSM solutions provider, *ITSM* is the *planning, delivery, and suuport of IT services via a mix of people, processes and technology(ServiceNow, n.d)*. In a wake to improve customer satisfaction and improve IT services, ServiceNow has integrated AI & ML in the ITSM solution products to assist in common help desk tasks like phone calls and determining shortages in IT resources.

According to Atlasian, there are seven core ITSM processes covering all ITSM activities regardless of the technology level(manual or automated). These prcesses are presented on the image below.

Source: Atlassian (n.d.). Used with permission.

These processes are described as follows:

1. *Service request management*

Also known as servicedesk/helpdesk, it focus on the procedure of receiving and responding to request. Best practice is leveraging chatbots or self-service options to maintain uniform responses to similar requests.

2. *Service catalog*

This is a helpdesk web page with links to self-service solutions, accessible only by employees, a group of users, or members of an organization/institution, for common issues/problems and helpdesk contact information. The service catalog helps reduce the number of incidents the IT or helpdesk team receive. Hence, creating more time for IT and the helpdesk to focus on more serious issues.

3. *Knwoledge, policy, and procedure*

This is a knowledge base created for the collection, maintenance, distribution and sharing of information throughout an organization. It could be accessible to everyone or restricted based on factors like organizational culture, employee rank/position, identity access management (iam) policy/procedure. To avoid creating redundant solutions, a company should not be overly strick on granting access to the knowledge base. A knowledge base typically stores information like digital or paper artifacts, shared documents,

proprietary software, client list, revenue/pricing data, compensation data, standard forms, templates, contracts/SLAs etc,.

4. *Indident Management*

The main aim of an incident management tool is to minimize system down times that could arise from hardware, software or system issues preventing employees from performing their duties. For instance, inappriopriate software installations or updates could throw an error blue screen preventing an employee from being able to login into the conpany's network. Incident management is also available as self-service or helpdesk, and its performance is measured by the reduction rate of the overall number of incidents.

5. *Problem Management*

This involves attepts to solve known and unkwon problems which cannot be resolved by the normal incident management. All problems should be logged and tracked as they progress toward closeout or completion.

6. *Asset Management*

IT Asset management is the core process for keeping track and maintaining the inventory of IT assets used in an organization. Assets include hardware, software, and data. IT asset management is a lifecycle that starts with asset acquisition through deployement and use, then ends at disposal at the end of an assets life.

7. *Change Management*

Due to situations like increasing workloads in an organisation or technological improvements, an organisation may have to change, upgrade or modify its systems. This is done in the process of change of management.

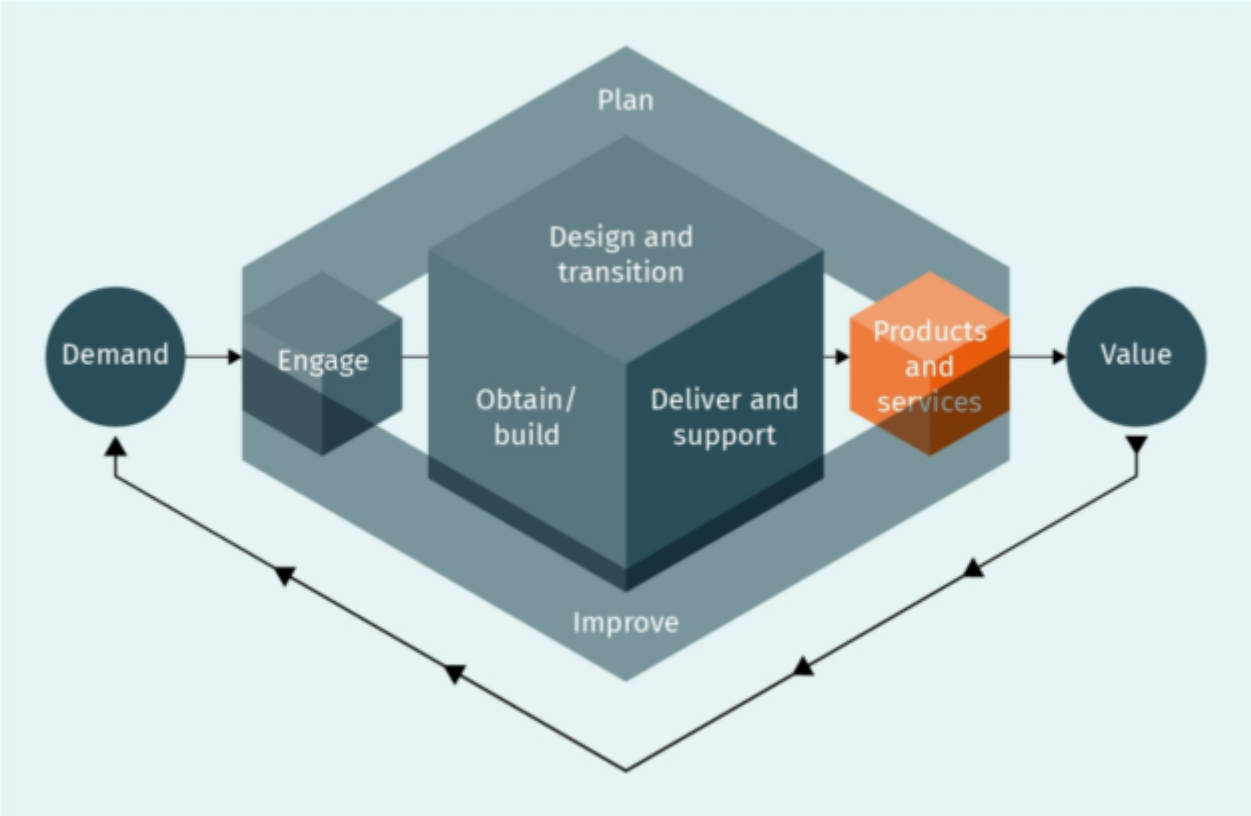
What is ITIL V4?

Information Technology Infrastructure Library is initially a britisch government best practice for efficient use of resource and waste management in IT service delivery. Today it has been adopted by the private and public sector as the standard or framework for providing best practices in ITSM. The first version was published in 1989 and the latest version was released in 2019. ITIL V4 is composed of five major parts collectively known as *Service Value System (SVS)*. These components are:

A. Service Value Chain (SVC) which has six activities or steps B. seven guiding principles C. a collection of 34 ITIL practices, broken down into three subject areas which are: *general management practices, service management practices, and technology management practices* D. governance, and E. continual improvement

A. Service Value Chaing

Additionally, ITIL V4 also contains a service model which is based on four dimensions of service management. The following figure illustrates the ITIL Service Value Chain concept with six service value chain activities.



Source: Moometric.com (2020). Used with permission.

These six service value chain activities are described as follows

1. *Plan*

In this activity, input requirements are gathered. Inputs could be elements required by law or regulations(e.g data minimisation). The output includes the engaged activity to maintain gathered requirements. For instance, taking measures to maintain service level agreements.

2. *Improve*

Monitoring and measuring performance and quality levels to check for improvements. Input include performance reports and output could be a report detailing all identified issues requiring follow-up.

3. *Engage*

These are specific activities from vendors/employees/customers aimed at communicating or creating awareness towards **value, demand, requirements, reporting, improvements and performance**.

4. *Design and transition*

This activity incorporates stakeholder requirements or needs into the service, or product and ensuring that expectation related to delivery deadline, quality standards and allocated budget are met.

5. *Obtain/build*

This activities entails getting resources required to build a product or service then actually building the product/service. At every step of the building process, testing must be done. Interactions with suppliers and quality control are critical for ensuring that stakeholder expectations are being met accordingly at each

progress step or milestone. Contracts and communications with vendors and clients are basic elements of this activity.

6. *Deliver and support*

In most cases, this is the final service value chain activity and it consist of delivering the product/service to the customer. Additional services of this activity is providing quality customer service and acceptable response time for support issues.

B. ITIL V4's Seven Guiding Principles

Source: Logitrain (2020). Used with permission.

These principles are best practices which act as a code of ethics and are also found in othe frameworks and standards apart from ITIL. These principles are described as next:

1. *Focus on value*

The service provider should add value to a service through quality improvements.

2. *Start where you are*

Make use of current tools and avoid trying to invent the wheel.

3. *Progress iteratively with feedback*

Create feedback loops at every major level of the product/service development to create room for identification of issues and improvements. This also helps to keep every active stakeholder in the development process upto date ensuring that all parties have the same level of understanding.

4. *Colloborate and promote visibility*

The development process should be charactirised by information sharing and collective support. No one should have monopoly of knowledge. Also ensure that everyone feels appreciated and motivated.

5. *Think and work holistically*

The development process should be transparent, clear an visible to every stakeholder.

6. *Keep it simple and practical*

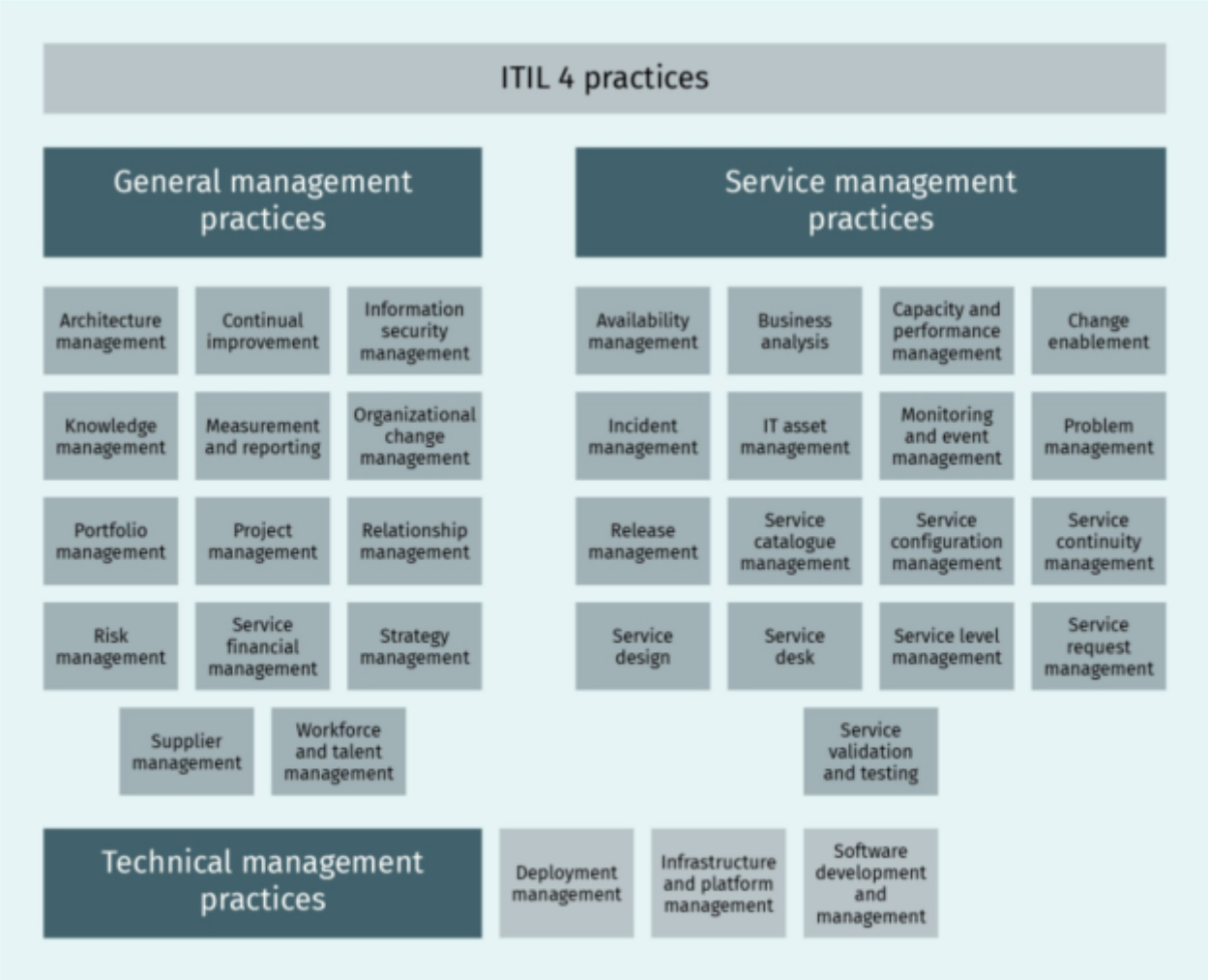
Eliminate every possible redundancies in the development process and keep only those steps or behaviours that add value or enrich the product development life cycle. Example, eliminate unnecessary meetings

7. *Optimize and automate*

Where possible, manual work should be replaced via automations. As a result resources could be redirected to other areas.

C. ITIL Management Practices

Unlike the distinction between governance and management activities as discussed in COBIT 2019, the key entity terms in ITIL management are: **general management practices, service management practices and technical management practices**.



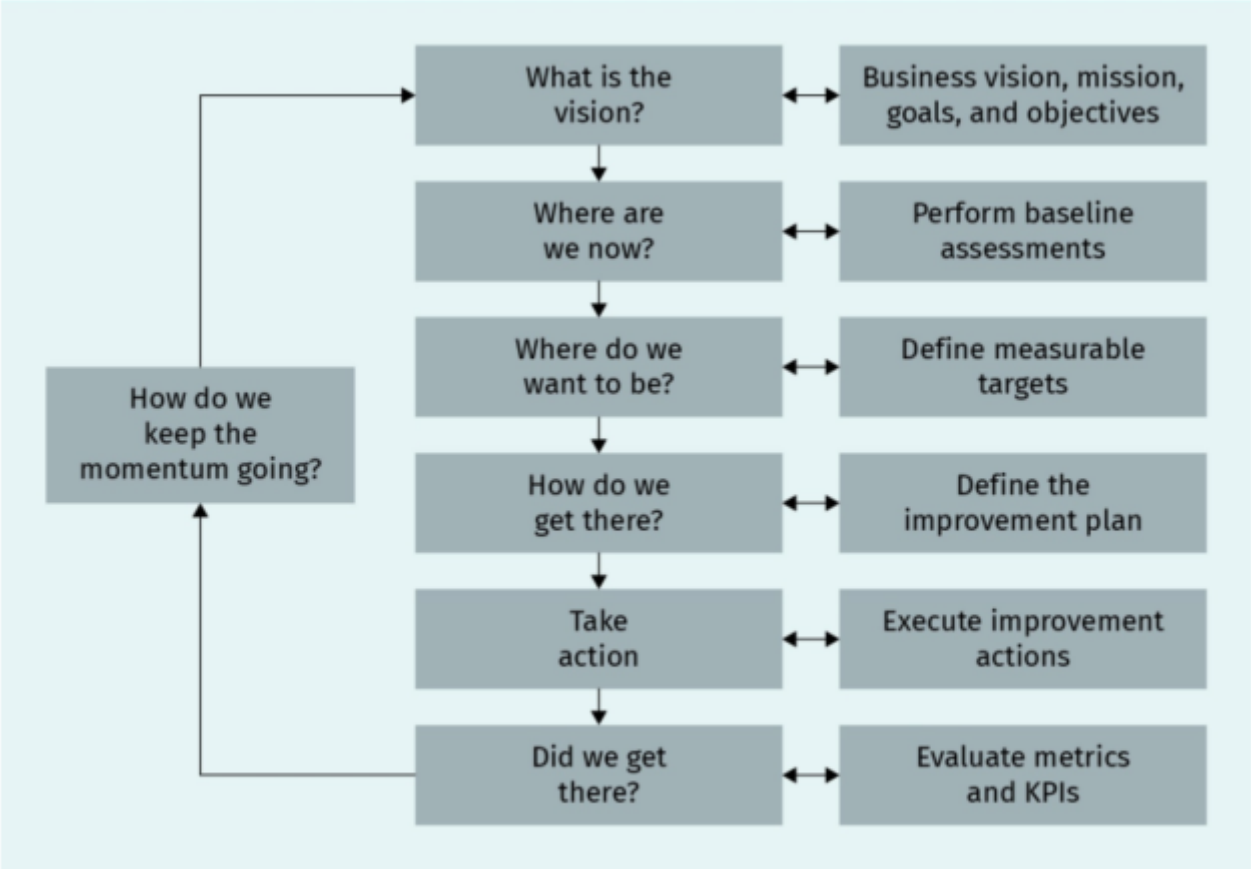
Source: YaSM (2019). [CC BY-ND 4.0].

D. What is SVC for governance?

pass

E. What is SVC for continuous improvement?

Continuous improvement is represented by a flowchart of questions and answers which act as a guide for maintaining or improving service quality. This is illustrated in the following figure:



Source: Moometric.com (2020). Used with permission.

The four dimensions in ITIL 4

1. *Organisation and people*

- Examination of soft and hard skills
- Aligning people to the organisation's goals

2. *Information and Technology*

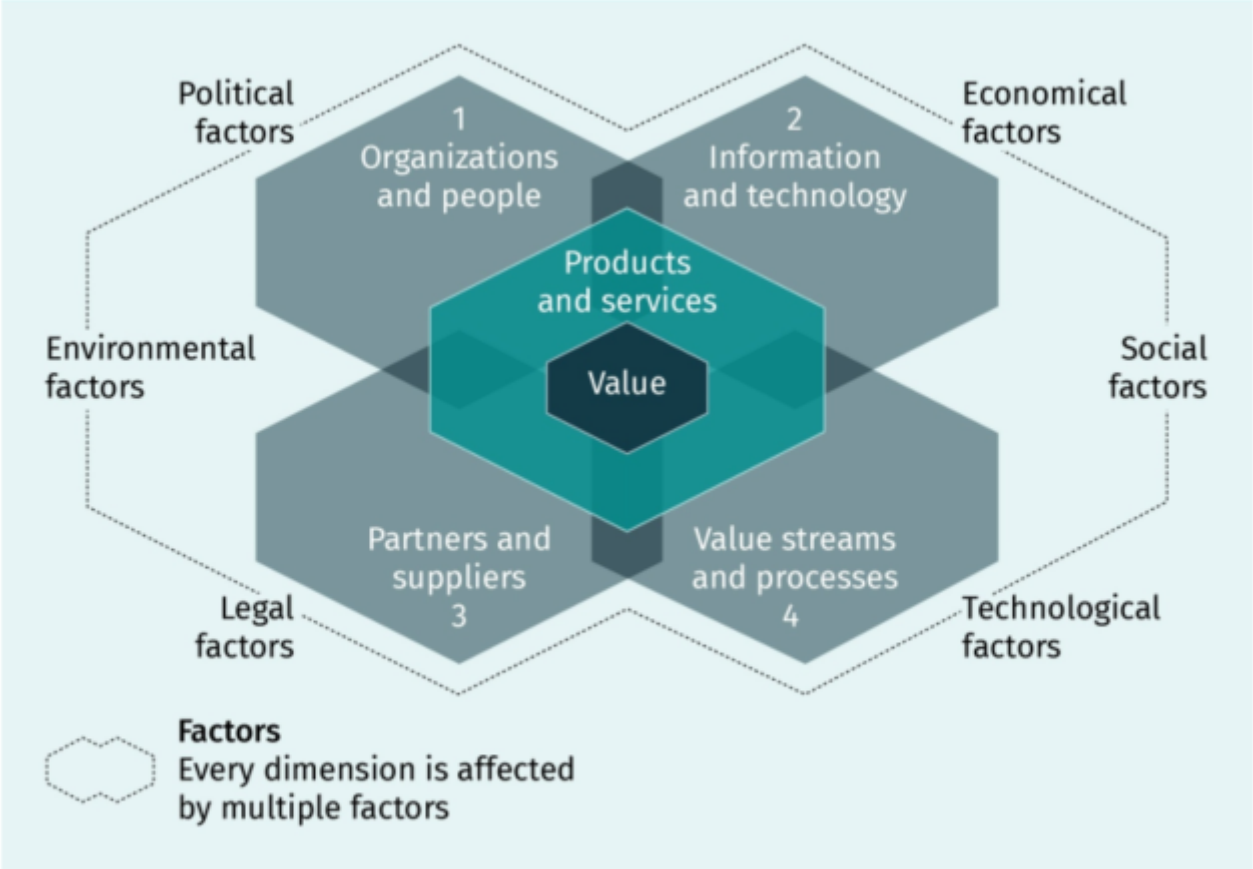
- Data driven services
- Automation for quality improvement and efficiency

3. *Partner and Suppliers*

- Selecting a vendor
- Monitoring and measuring the performance of the selected vendor's services/products with respect to contract requirements

4. *Value Streams and Processes*

- Quality must be of expected standard at all levels from processes to the entire product/service. I.e the parts should be as good as the whole.



Source: Symphony Summit AI (2021). Used with permission.

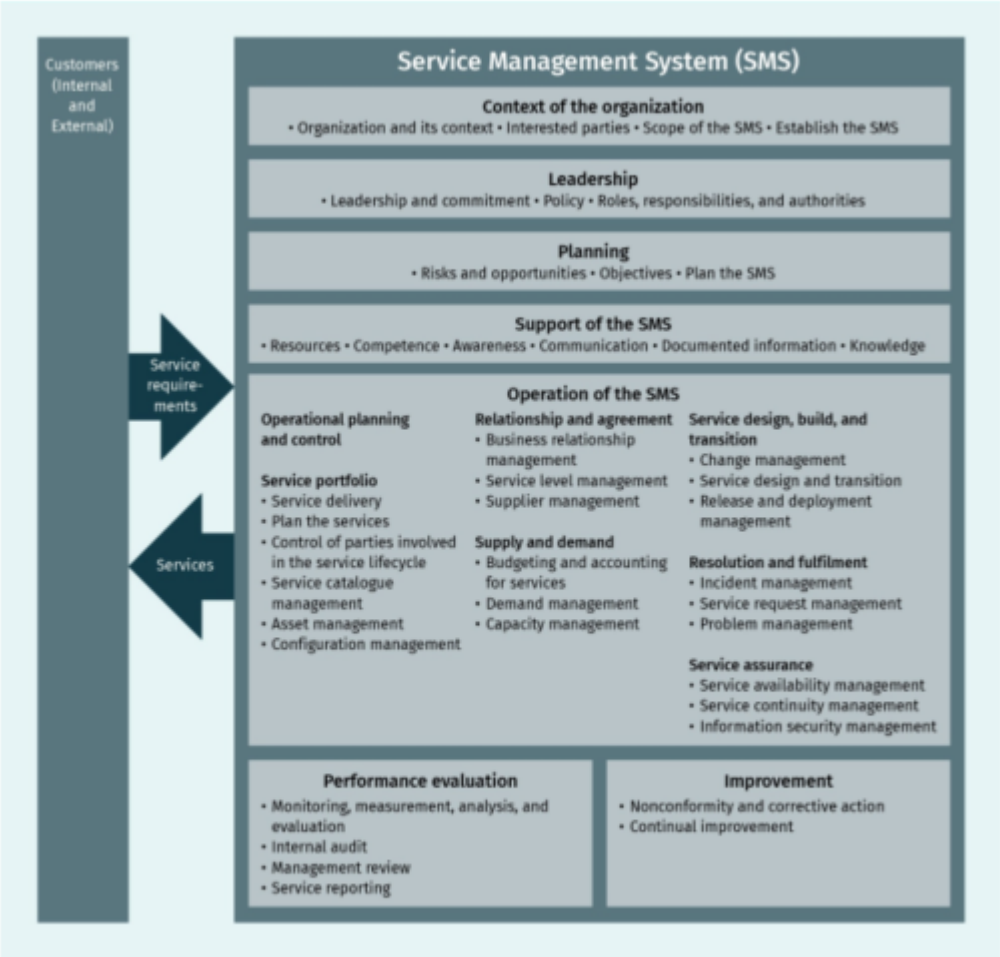
In an organization, the IT Service manager is in charge of handling the ITIL V4 responsibilities. The person incharge of ITIL tasks should be familiar with the firms service catalog and should have at least one IT certification.

What is ISO/IEC 20000-1:2018?

This global standard for ITSM was created by the British International Organaisation for Standardisation (ISO). ISO is an independent non-governmental organisation with a membership of 165 national standards. Unlike ITIL, this standard requires *mandatory items* i.e what one must have or do. This standard can also act as a complementary to the ITIL standard. This means that an organisation may start its ITSM journey with ISO and later on complement with ITIL to implement ITIL best practices.

Structure and Contents

The ISO 20000-1:2018 is comprised of 10 clauses, 59 total processes and requirements for writen evidence to support actions taken to comply with the clauses and processes.



Source: International Organization for Standardization (2018b). Used with permission.

The ISO 20000-2018 uses the Service Management System Model (SMS), which includes the following 10 clauses with their respective processes. The SMS starts with chapter/clause 4 and goes through to chapter/clause 10. These chapters or clauses are described as follows:

- Chapter 1: scope Defines the scope of SMS
- Chapter 2: Normative references There are no citations which act as requirements
- Chapter 3: Terms and definitions Standard terms taken for IEC encyclopedia and ISO online platform.
- Chapter 4: Context of the organisations This clause integrates the SMS concept with stakeholder needs via the following processs:
    - 4.1 Understanding the organisation and its context
    - 4.2 Understanding the needs and expectations of stakeholders
    - 4.3 Determine and document the scope of the SMS
    - 4.4 The service management system
- Chapter 5: Leadership This clause expects an organisation to have a formal leadership structure in place for service management, and includes the following processes:
    - 5.1: Leadership & commitment: an approved budget item
    - 5.2 Policy: Policies must be written in a document
        - 5.2.1 Establishing the SM policy
        - 5.2.2 Communicating the SM policy
    - 5.3 Organisational roles, responsibilities and authorities.
- Chapt 6: Planning An organisation must have an formal program to address service risks/opportunities and includes the following processes:

    - 6.1 Actions to address risks and opportunities
    - 6.2 Service management objectives and planning to achieve them
        - 6.2.1 Establish objectives
        - 6.2.2 Plan to achieve objectives: "How are we going to do this?".
    - 6.3 Plan the service management system
- Chapter 7: Support for the SMS This clause requires an organisation to dispose resources to support SMS. This includes producing, maintaining/protecting, and updating related documents. The following processes are included:
    - 7.1 Resources: Ensure that the budget has allocated resources
    - 7.2 Competence: Ensure that an experienced team is available
    - 7.3 Awareness: Get the word out!
    - 7.4 Documented information: the entire 7.5 ensures that the program formalised with a budget.
    - 7.6 knowledge: Part of a formal program
- Chapter 8: Operation of the SMS Details for operating an organisation's SMS program are provided by this clause and overlaps with other clauses for some processes:
    - 8.1 Operational planning and control
    - 8.2 Service portfolio
    - 8.3 Relationship and agreement
    - 8.4 Supply and demand
    - 8.5 Service design, build and transition
    - 8.6 Resolution and fulfillment
    - 8.7 Service assurance
- Chapter 9: Performance evaluation This clause is concerned with the performance of the service management program and how this can be improved.This includs monitoring, audits, review and reporting.
- Chapter 10: Improvement Management actions to improve service when measured against the company's objectives.

Other ITSM Frameworks and Standards

Apart from ITIL and ISO 20000, other ITSM assessment tools exist which can drive an organisation toward increased efficiency and cost savings in its service delivery. Examples include

1. *TOFAG Framework* The open group architecture framework sterms from the U.S Department of Defense IT Management framework. Its focus is on enterprise-level workflows and enterprise architectures.

2. *MOF* The Microsoft Operations Framework has similarities with ITIL and focuses on the entire IT life cycle incorporating MS solutions frameworks best practices. It is often used with microsoft products and includes a version for cloud services.

3. *FitSM* This is an open souce free ITSM standard created through a grant from the european commission. It focuses on ITSM effectiveness.

4. *Six Sigma* Created by motorola, it focuses on quality and minimisíng defects in products and services. This framework is suitable for large organisations and is very popular with many Fortune 500 corporations.

Unit 6: IT Law

Overview of Relevant Lawss

1. Electronic commerce law (e-commerce law)
    - Regulates buying and selling of goods and services on the internet
    - In Germany Every website or webshop must have an Impressum according to the Telemediengesetzt
    - Impressum contains contact details like name, physical address, and two contacts.
    - Customer has the right to withdraw from a sale transaction without explanation(exception in health and safety cases or custom-made items). i.e return policy.
    - Customer personal data is crucial and must be handled with care.
2. Data protection, protection of minors, and general criminal regulation
    - Lowest age for special protection in the context of IT in the world is 13 but IT laws extends this to 16.
    - In most countries the is restriction on internet access to children.
    - Collection of PII for minors requires explicit consent from parents or legal guidians.
    - YouTube was fined 170 m us dollars in 2019 for collecting minors PII without explicit consent of parents
3. Domain law
    - Protects domain name infringement
    - Infringement can be in the form of cybersquatting or typosquatting
    - Cybersquatting occurs when someone acquires and registers a domain that is already registered. This activity is illegal.
    - Typosquatting occurs when a domain name is slightly altered to divert users to the unintended site.
4. Competition law
    - Laws that prevent the creation of monopolies or ends existing monopolies to encourage competition in business
5. German Telemedia Act
    - Telemediengesetz mandates video posting websites to provide a formal reporting system for reporting violations. e.g ads targeting children, ads promoting criminal content.
    - This law mandates every website in germany to have an impressum
    - Every website must provide liability resolution and liability for content on their website
    - All providers of services on the internet with the exception of those listed on the next point are uplarge to monitor data transmitted or stored by the providers and must monitor for illegal activities
    - access providers, service providers, caching providers, telecommunication providers and hosting providers
6. Legal requirements for handling emails
    - Email archives should be establish as a means of preserving evidence. This is required by banks and healthcare

    - Emails shouls be encrypted before being sent out externally or prohibit the sharing of senitive data via email.
    - The UWG(Gesetzt gegen den unlauteren Wettbewerb) stricktly regulates email marketing in germany.
    - The UWG define restrictions on email marketing including explicit consent, right to withdraw consent, and accuracy of product claims/statements.
    - The GDPR and EU's e-privacy must be considered in direct marketing in Germany.

7. IT security/breach notification law

    - Breach notifications are actions to be taken to protect personal data from unauthorised access when a breach occurs.
    - Users are also informed about the breach within a specified time frame
    - The GDPR defines a 72 hours time frame for controlers to report breaches to applicable data protection authority, from the time the breach was detected.
    - In some countries like the U.S attempted unauthorised access to data must be reported
    - Remember the roles of Controler, Processor and data subject as defined in GDPR.
    - Many breach notifications and privacy laws require data privacy and data security which are the two basic elements of cybersecurity.

8. Intellectual property protection (IP)

This field of law protects inventors and creators of scientific, commercial, or artistic inventions or expressions. IP protects patented inventions, trademarks, copyrighted material, softwarem hardware, AI and blockchain applications. Laws that fall under IP include the following:

```
- 7.1 *Patent Law*: Protection of discovery or invention from theft for a period
of time. Inventor must show basic information about the invention and must
register this against a fee by a patent office. If a patent is violated, the
inventor can sue and get financial benefits if successful. Example of patent
offices or firms are: Worl Intellectual Property Organisation (WIPO), U.S. Patent
and Trademark Office (USPTO).
- 7.2 *U.S. patent law*
- 7.3 *German patent law (Patentgesetz)*: This is the german patent law. To obtain
a patent, designation of the sole inventor, examination process and fee is
involved. If approved, the patent is valid for 20 years from the filling date. For
technical inventors, a utility model german patent is granted for a period of ten
years from filling. The European Patent Office grants patents which are recognised
in Germany.
- 7.4 *Copyright*: Software use also covers user rights. Software protection can
range from very strict(protection by copyright, license or trademarks) to very
open(software is either free, almost free and is available as open source,
freeware or shareware). A copyright protects and expression of an underlying work.
Copyright for software and web-based apps protects the source code, object code
and related materials such as help notes and user manuals. Copyright infringement
is often known as piracy.
- 7.5 *Creative common licenses*
```

8. IT contract law

Generally called *Service Level Agreement* and is concerns both vendor and client in protecting data exchange between them. The following are the types of IT Contracts.

```
- 8.1 *Software contracts*
- 8.2 *Contracts for work and services*
- 8.3 *Warranty and guarantee*
- 8.4 *Terms and conditions*
- 8.5 *Contractual penalties*
- 8.6 *Acceptance of software*
- 8.7 *Outsourcing contracts*
```

Privacy

Visit GDPR in the course *concepts in data management*